

Guia Inicial - OFFSEC



Muito boas-vindas ao OFFSEC!!!

Somos um projeto de extensão focado no estudo e no desenvolvimento de materiais e palestras sobre segurança ofensiva e hacking ético. Nosso principal objetivo é capacitar os alunos com conhecimentos práticos em cibersegurança, **sempre seguindo princípios éticos e legais**.

O grupo trabalha com:

- Criação de material didático
- Participação e Desenvolvimento de CTFs (Capture The Flag)

Este guia serve para você dar o passo inicial. Ele aborda os conceitos essenciais e ensina como instalar as ferramentas necessárias. Ao seguir estas orientações, você estará apto para invadir a sua primeira máquina virtual!

Sumário

- [Segurança Ofensiva](#)
 - [Ferramentas Necessárias](#)
 - [Conceitos Básicos](#)
-

Segurança Ofensiva

No mundo da cibersegurança, nós temos três áreas principais:

- **Blue Team:** Responsável pela defesa. É a equipe que protege o sistema, monitora as redes, detecta ameaças e bloqueia os ataques na prática.
- **Purple Team:** Responsável pela integração. Funciona como uma ponte entre o ataque e a defesa, garantindo que as táticas e descobertas do Red Team sejam usadas para melhorar ativamente as proteções do Blue Team.
- **Red Team:** Responsável pelo ataque. É quem simula ataques do mundo real e testa as vulnerabilidades dos sistemas para descobrir onde estão as falhas antes que um cibercriminoso de verdade o faça.

O OFFSEC atua como um Red Team. Estudamos para nos tornarmos Hackers Éticos, aplicando o conceito de "atacar para defender". Para solidificar nosso conhecimento, praticamos nossas habilidades em plataformas que disponibilizam máquinas virtuais para ataques autorizados:

- [Try HackMe](#)
- [Hack The Box](#)

Esses serviços nos fornecem a permissão necessária para operarmos legalmente dentro da segurança ofensiva.

Warning

Só executamos testes de intrusão em ambientes onde temos permissão expressa e documentada (Labs, CTFs, Contratos). É estritamente proibida a prática ilegal dessas atividades.

Ferramentas Necessárias

Utilizaremos o VirtualBox para virtualizar nosso sistema operacional focado em segurança, o Kali Linux. O VirtualBox é um software que permite criar e gerenciar máquinas isoladas dentro do seu próprio computador, garantindo que sua máquina pessoal permaneça íntegra e segura durante os testes

O Kali Linux é o ambiente virtualizado padrão da indústria. Trata-se de uma distribuição Linux pré-configurada com centenas de ferramentas de segurança, que opera de forma totalmente independente do seu hardware principal. Você pode acompanhar a configuração inicial através da documentação oficial do nosso repositório no GitHub: [\[00\] - setup](#)

Ou utilizando tutoriais recomendados nesse vídeo: [Tutorial instalação do Kali Linux](#) *Sigam o tutorial até os 02:16 minutos, o restante do vídeo não é necessário*

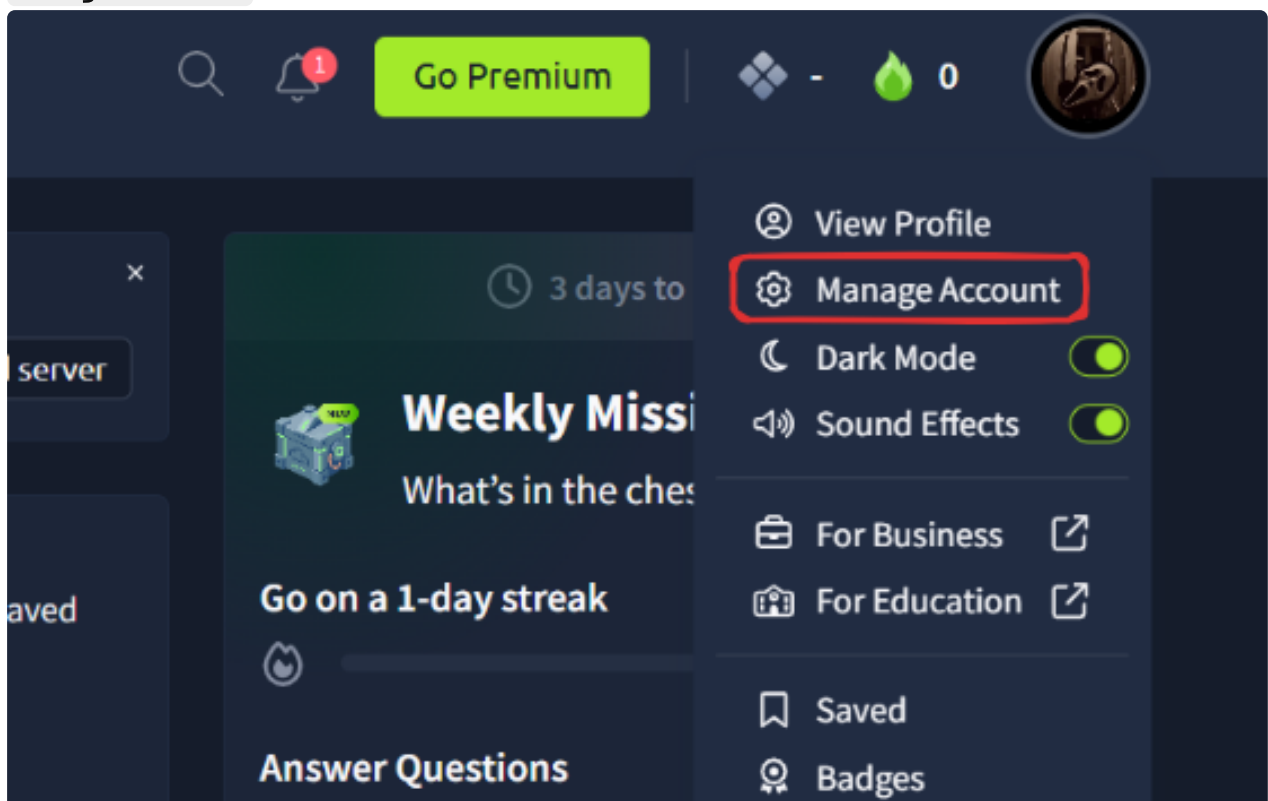
Como baixar a VPN?

A VPN do TryHackMe deve ser baixada para que seja possível vocês estabelecerem uma conexão segura com o site, só assim poderão fazer o CTF e se conectar a máquina que será atacada.

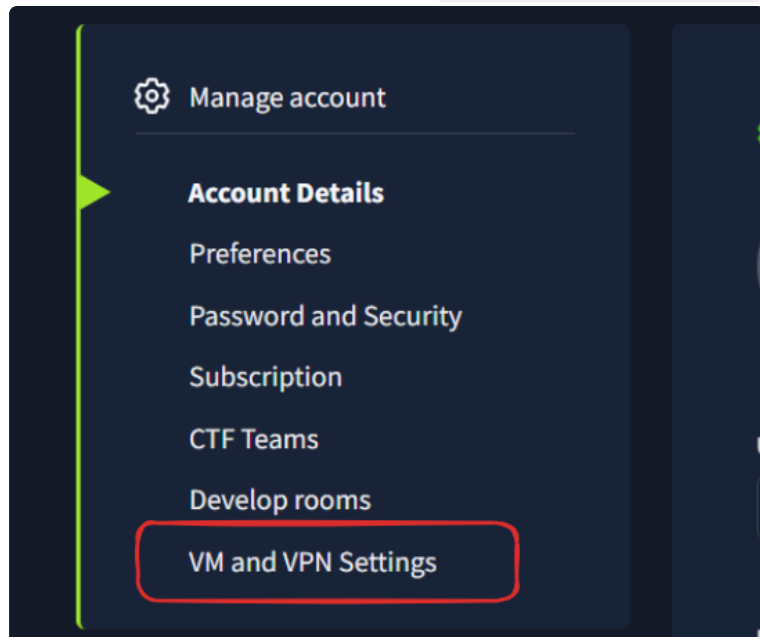
Para baixar sigam os passos abaixo:

1. Vá em <https://tryhackme.com/access> ou clique na imagem do seu perfil e acesse

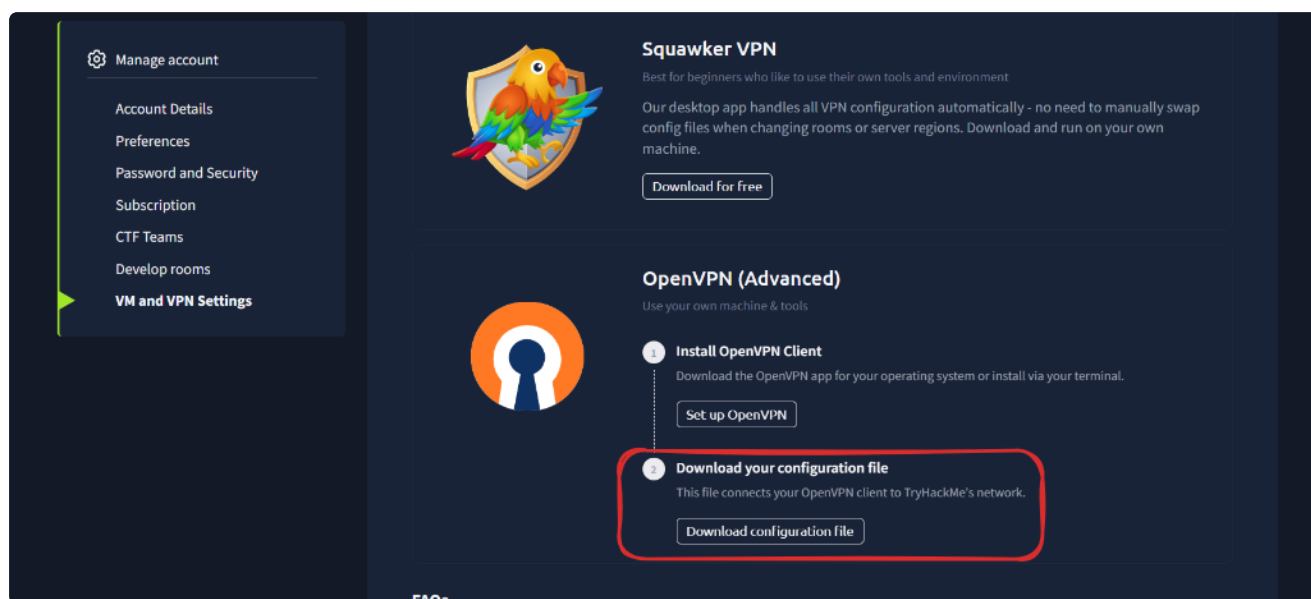
Manage Account



Depois, na aba lateral, vá em **VM and VPN Settings**



2. Na parte **OpenVPN (Advanced)** baixe a VPN em **Download configuration file**



No Kali, para ativar a VPN, abra um terminal e execute:

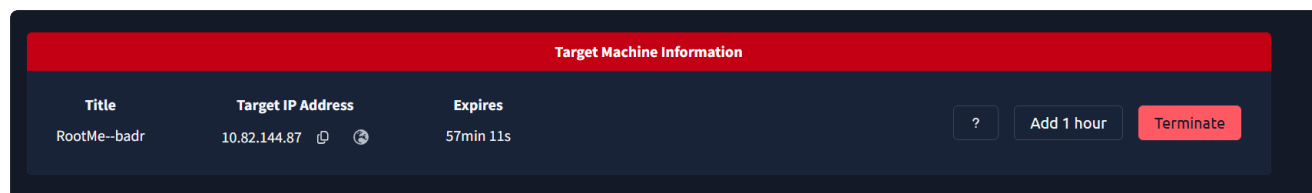
```
sudo apt install openvpn  
sudo openvpn ~/Downloads/seuarquivo.ovpn
```

Iniciando uma Máquina no TryHackMe:

Na página inicial do TryHackMe, vá em **Practice > Challenges** para ter acesso aos desafios disponíveis, recomendo vocês filtrarem para: **Type > Red**, **Difficulty > Easy** e

Subscription Type > Free, ele listará todas os desafios (CTF's) que vocês podem tentar fazer.

Para iniciar o desafio vocês devem clicar em **Join Room** e depois **Start Lab Machine**. Pronto, a máquina que você irá atacar ficará disponível para você, a partir de agora vocês terão um IP, esse sempre vai ser a base do nosso ataque, ele serve para identificar essa máquina específica que vocês acabaram de instanciar.



Tomem cuidado com esse tempo, se vocês não adicionarem mais tempo, ele desligará a máquina em uma hora.

Conceitos Básicos:

Antes de vocês fazerem o CTF, precisam ter noção de alguns termos e conceitos básicos:

- **Endereço IP:** Todo dispositivo conectado a uma rede precisa de um identificador único para se comunicar, como se fosse o endereço de uma casa. No nosso caso, quando você inicia um desafio no TryHackMe, ele te dá o IP do alvo. É exatamente esse IP que a gente vai atacar.
- **VPN:** Normalmente a VPN é utilizada para esconder a sua localização na internet, mas no contexto do CTF, utilizamos para conseguir entrar na mesma rede da máquina alvo. Sem isso, você não consegue ver o seu alvo.
- **Diretório:** É basicamente uma pasta, os sites organizam seus arquivos e páginas em diretórios, como `site.com/admin`. Achar diretórios escondidos é essencial na fase de Enumeração, porque é lá que a gente pode achar uma tela de login esquecida ou um arquivo importante.
- **Portas:** Todo IP tem várias portas onde diferentes serviços rodam. A porta 80 geralmente roda um site, enquanto a porta 22 roda o SSH.
- **Flag:** É o objetivo do CTF, *Capture The Flag*. É um arquivo de texto escondido na máquina alvo (`user.txt` ou `root.txt`) que contém um código, você deve copiar e colocar no THM (TryHackMe), é assim que você ganha pontos para provar que conseguiu invadir a máquina.
- **Shell e Reverse Shell:** A shell é o terminal, uma reverse shell é quando a gente explora uma falha no sistema e faz o computador do alvo se conectar de volta para o nosso

terminal no Kali. É com ela que a gente ganha acesso e começa a explorar a máquina hackeada.

- **Wordlist:** É um arquivo de texto gigante cheio de senhas, nomes de usuários ou de diretórios muito usados. Usamos essas listas prontas junto com ferramentas para testar milhares de possibilidades por segundo.
- **Exploit:** É o script, código ou comando que a gente usa para se aproveitar de uma vulnerabilidade que achamos no sistema alvo.

Ideia principal de um CTF

A resolução estruturada de um CTF segue uma metodologia cíclica:



Reconhecimento/Enumeração: Descubra o máximo de informações sobre o IP alvo. Utilize o terminal do Kali com ferramentas como o `nmap` para identificar serviços rodando nas portas e o `gobuster` para localizar diretórios ocultos na web. É importante buscar informações na página. Pode ter alguma informação no HTML, no JS, no CSS, ou em alguma figura. **SEU PAPEL É ACHAR INFORMAÇÕES QUE POSSA USAR.** Um login, senha, subdomínio, etc

Acesso Inicial/Exploração: Utilizando exploits, injeções de código ou obtendo uma reverse shell, você se aproveita das vulnerabilidades encontradas na enumeração para penetrar o sistema alvo. Se não for possível explorar a máquina com as informações atuais, deve-se retornar à fase de Enumeração.

Escalação de Privilégios/Pós-Exploração: Ao conseguir o acesso inicial, você geralmente adquire permissões restritas de um usuário comum. A escalação consiste em investigar configurações incorretas, senhas esquecidas ou permissões fracas para elevar o seu nível de acesso, até atingir o usuário administrador, obtendo controle total da infraestrutura para capturar a flag final.

A ideia principal de exploração é essa:



Note

Enumerei, colhi informação, da pra explorar? Se não, volta para a Enumeração

Abaixo, estão explicadas detalhadamente cada parte do processo:

Enumeração

Pronto, agora que temos uma VPN pra fazer a conexão segura e um IP da máquina que vamos atacar, precisamos começar a entender um pouco mais sobre o nosso objetivo. Para isso, utilizamos uma ferramenta chamada `nmap`, ela consegue nos dizer quais serviços estão rodando no IP, ou seja, se existe algum site, um ssh, um ftp, etc.

Para rodar o Nmap e a maioria das nossas ferramentas, nós vamos usar o **Terminal** do Kali Linux (o ícone quadrado preto que fica no canto superior esquerdo da tela). Abra o terminal,

digite o comando abaixo substituindo `<IP_ALVO>` pelo IP da máquina do TryHackMe e aperte Enter:

```
nmap -sV -sC -v <IP_ALVO>
```

O `-sV`, `-sC` e `-v` são o que chamamos de flag, servem para complementar a ferramenta, então, como exemplo, a flag `-sV` mostra a versão do serviço que está rodando.

Assim que terminar de rodar você terá algo como isso:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 8f:da:27:a3:f5:3e:26:cd:c2:4f:48:ca:62:45:02:61 (RSA)
|   256 72:7a:24:41:c8:46:46:7d:1c:59:3f:eb:e3:96:8c:87 (ECDSA)
|_  256 bf:37:0f:a1:5e:8c:81:39:3f:65:b4:c5:72:1f:8a:a4 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: HackIT - Home
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|   httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Aqui nós temos um serviço `http` rodando na porta 80 e um serviço `ssh` rodando na porta 22. Essas são as portas comuns para esses serviços.

Para acessar o site, nós digitamos na barra de busca do seu navegador, o ip da máquina alvo.

Para conseguirmos descobrir se existe algum diretório escondido, usamos a ferramenta chamada `gobuster` e o seu comando é:

```
gobuster dir -u https://exemplo.com -w wordlist.txt
```

Resultando em:

```

$ gobuster dir -u 10.64.166.243 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://10.64.166.243
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.8
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

/.hta                (Status: 403) [Size: 278]
/.htpasswd            (Status: 403) [Size: 278]
/.htaccess            (Status: 403) [Size: 278]
/css                 (Status: 301) [Size: 312] [→ http://10.64.166.243/css/]
/index.php           (Status: 200) [Size: 616]
/js                  (Status: 301) [Size: 311] [→ http://10.64.166.243/js/]
/panel               (Status: 301) [Size: 314] [→ http://10.64.166.243/panel/]
/server-status       (Status: 403) [Size: 278]
/uploads             (Status: 301) [Size: 316] [→ http://10.64.166.243/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished

```

O *status* é o **código de status HTTP**, são mensagens que indicam o resultado de uma solicitação feita. Aqui estão alguns dos códigos mais comuns:

- **200** : O servidor processou a solicitação e retornou o conteúdo esperado.
- **404** : O servidor não encontrou a página solicitada.
- **301** : O servidor está redirecionando permanentemente a página para um novo endereço.
- **302** : O servidor está redirecionando temporariamente a página para um novo endereço.

O próximo passo, em um CTF, seria acessar esses diretórios para descobrir se existe alguma forma de garantir acesso ao IP alvo. Existem várias formas de se fazer isso, seja com uma shell reversa, com um Exploit ou n de outros jeitos.

Exploits

Um exploit é basicamente um código, script ou técnica que se aproveita de uma vulnerabilidade que você encontrou no alvo, um software desatualizado ou uma página web que aceita upload de arquivos maliciosos.

O objetivo principal dessa etapa é conseguir o que chamamos de *acesso inicial*. Na maioria dos CTF's, isso significa conseguir uma Reverse Shell.

Escalação de privilégios

Parabéns, você conseguiu entrar na máquina. Quando você ganha o acesso inicial, quase sempre entra como um usuário comum. Para realmente ter total controle do sistema, você precisa se tornar o administrador máximo, chamado de **root**. A escalação de privilégios é o processo de caçar configurações erradas, senhas esquecidas em arquivos ou permissões

mal configuradas que permitam seu usuário executar comandos como administrador. Quando você vira **root**, você tem controle absoluto da máquina e consegue pegar a última flag.

Write-ups

Um write-up é basicamente um relatório detalhando o passo a passo de como você resolveu um CTF, desde a enumeração inicial até a escalção de privilégio.

No mercado de trabalho, quando você atua como Red Team, o seu produto final é o relatório, você precisa provar para a empresa que te contratou como você invadiu o sistema, qual é o risco real daquela falha e como a equipe deles pode corrigir o problema.

Além de te preparar para um futuro no mercado, os write-ups te ajudam a organizar o seu raciocínio e a criar o seu próprio material de consulta.

Note

Sempre que terminar uma máquina, tire um tempo para escrever como você resolveu. Se travar no meio do caminho, ler write-ups de outras pessoas também é uma das melhores formas de aprender técnicas novas.

Reuniões

Toda **quinta-feira**, exceto feriados, das **09:00 às 11:00** no **laboratório 120 bloco C**.

Para quem não puder participar presencialmente, entre em contato.

Link do nosso GitHub: <https://github.com/UFSC-OFFSEC/pwnbase>